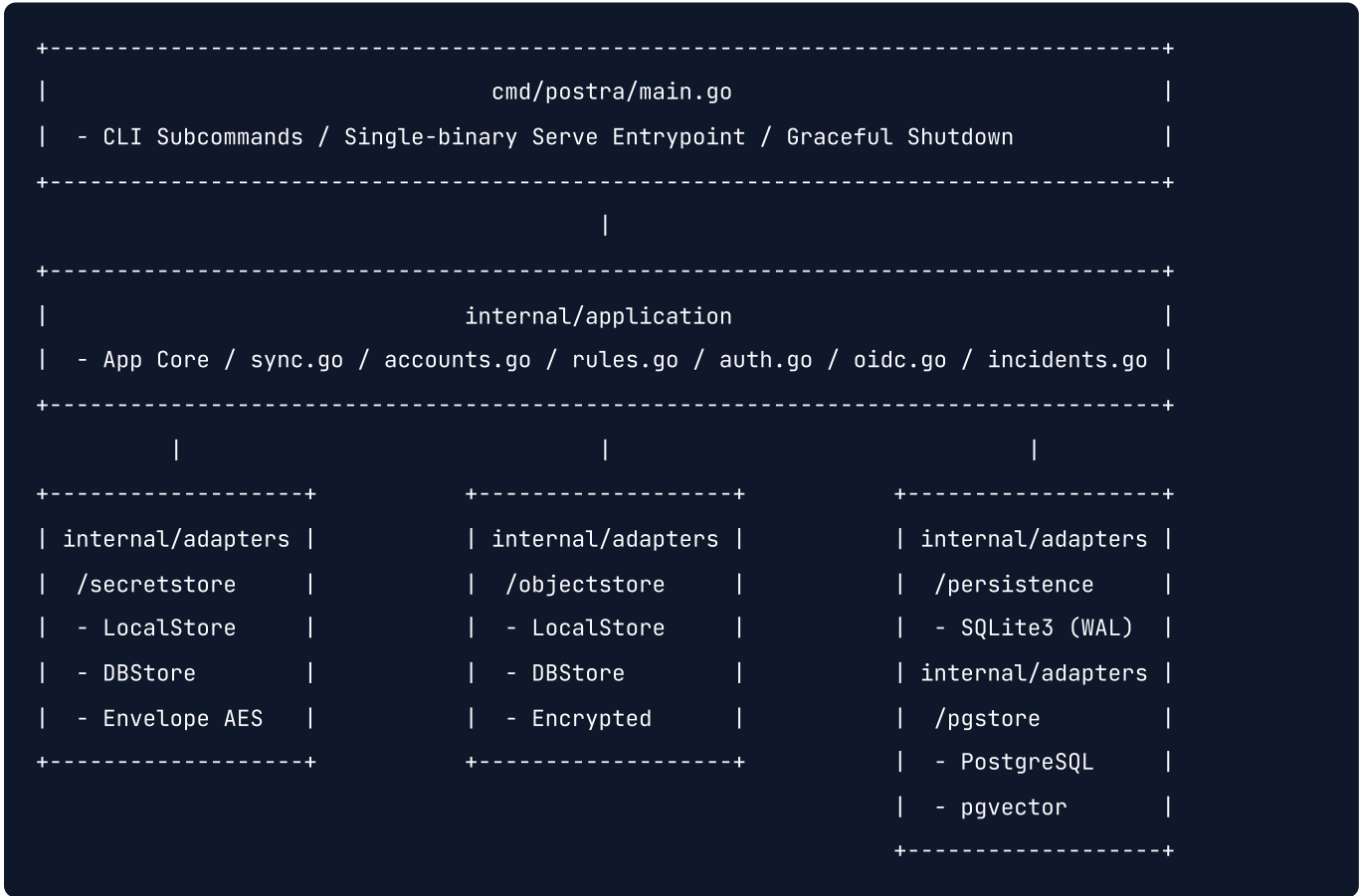


문서 관리 정보

- 소속: AI Infra실 (AI Infra Department)
- 문서 버전: v0.10.5
- 최종 수정일: 2026년 7월 24일
- 대상: 시스템 관리자, DevOps/Infra 엔지니어, 보안 담당자

Postra는 단일 바이너리 배포부터 K8s 기반 다중 노드 고가용성(HA) 아키텍처까지 확장 가능하도록 Hexagonal Architecture 포트-어댑터 패턴으로 구성되어 있습니다.



- `cmd/posta` : 서버커맨드(`init` , `serve` , `mcp` , `account` , `secret` , `sync` , `search` 등) 핸들러 및 SIGTERM/SIGINT 수거 루틴
- `internal/application` : 비즈니스 유스케이스 코어 (`App` , `Sync` , `Account` , `Rule` , `Auth` , `OIDC` , `Incident`)

- `internal/domain` : 도메인 엔티티 정의 (`Message` , `MailAccount` , `SecretHandle` , `Incident` , `Job`)
- `internal/adapters/secretstore` : AES-256-GCM Envelope 암호화 레코드 스토어 (`LocalStore` , `DBStore`)
- `internal/adapters/objectstore` : 메일 원문 MIME 및 첨부파일 암호화 객체 스토어 (`LocalStore` , `DBObjectStore` , `EncryptedStore`)
- `internal/adapters/persistence` : SQLite3 데이터베이스 어댑터 (WAL 모드, FK 활성화)
- `internal/adapters/pgstore` : PostgreSQL + pgvector 인덱스 지원 어댑터
- `internal/adapters/mailparse` : RFC822/MIME 디코더 및 `bluemonday` HTML Safe 세니타이저
- `internal/adapters/malware` : ClamAV 및 YARA 연동 첨부파일 보안 검사 엔진
- `internal/transport/httpapi` : REST API 핸들러 (`/api/...`) 및 API 토큰 인증 미들웨어
- `internal/transport/webui` : HTML 템플릿 웹 인터페이스 (`/ui/...`)
- `internal/transport/mcpserver` : Model Context Protocol SSE 및 Streamable HTTP 서비스 (`/mcp`)

2. 배포 및 환경변수 완벽 레퍼런스 (Environment Configuration)

Postras는 설정 파일(`config.json`) 또는 환경변수(`POSTRA_*`)를 통해 동작을 정밀하게 제어합니다.

2.1 전체 환경변수 레퍼런스 표

환경변수명	기본값	설명
POSTRA_HTTP_ADDR	127.0.0.1:8480	REST API, Web UI, MCP 통합 HTTP 바인딩 주소
POSTRA_DATA_DIR	./data	DB, 원문/첨부 객체, KEK 파일 저장 루트 디렉터리
POSTRA_STORAGE_DRIVER	sqlite	데이터베이스 드라이버 (<code>sqlite</code> 또는 <code>postgres</code>)
POSTRA_DATABASE_URL	-	PostgreSQL 접속 DSN (<code>postgres://user:pass@host:5432/db?sslmode=disable</code>)
POSTRA_SECRET_STORE_DRIVER	local	비밀값 저장소 드라이버 (<code>local</code> 파일 또는 <code>db</code>)
POSTRA_OBJECT_STORE_DRIVER	local	객체 저장소 드라이버 (<code>local</code> 파일 또는 <code>db</code>)
POSTRA_KEK	-	Base64 인코딩 32-Byte 마스터 KEK 키 (외부 주입 권장)
POSTRA_ALLOW_INSECURE_MAIL	false	평문 POP3/SMTP 허용 여부 (<code>true</code> 시 개발/테스트 용 허용)
POSTRA_BOOTSTRAP_ADMIN_PASSWORD	-	시스템 최초 시작 시 생성될 어드민 비밀번호
POSTRA_API_TOKEN	-	외부 HTTP 접근 시 헤더 인증 토큰 (<code>Authorization: Bearer</code>)
POSTRA_WORKER_ENABLED	true	백그라운드 리더 선출, 스케줄러, 동기화 워커 활성화 여부
POSTRA_AUTO_SYNC_MINUTES	5	메일 자동 수집 수신 주기 (분 단위, <code>0</code> 지정 시 비활성화)
POSTRA_OIDC_ENABLED	false	OIDC/OAuth2 SSO 연동 활성화 여부
POSTRA_OIDC_ISSUER	-	OIDC Provider Issuer URL (예: <code>https://auth.company.com/realms/main</code>)
POSTRA_OIDC_CLIENT_ID	-	OIDC Client ID
POSTRA_OIDC_CLIENT_SECRET_REF	-	암호화 SecretStore에 등록된 OIDC Client Secret 참조 키
POSTRA_OIDC_AUTO_LOGIN	false	Keycloak 세션이 있는 사용자를 로그인 화면 없이 자동 로그인 (silent SSO, <code>prompt=none</code>). 관리 화면 <code>auth.oidc.auto_login</code> 으로도 설정
POSTRA_VECTOR_STORE_DRIVER	db	의미론적 벡터 검색 드라이버 (<code>db</code> 또는 <code>milvus</code>)

환경변수명	기본값	설명
POSTRA_OPENAI_API_KEY_REF	-	AI 임베딩 생성용 OpenAI 호환 API Key 비밀값 참조 키

3. 어드민 계정 및 SSO 관리 (Identity & Authentication)

3.1 어드민 계정 멱등성 초기화 (EnsureUser)

Postrа 기동 시 `bootstrapAdmin` 프로세스가 실행되어 어드민 계정(`admin@postra.local`)을 검증합니다.

- **SQLite 쿼리:** `INSERT INTO users ... ON CONFLICT(login_id) DO UPDATE SET ...`
- **PostgreSQL 쿼리:** `INSERT INTO users ... ON CONFLICT (login_id) DO UPDATE SET ...`
- `SQLSTATE 23505 (users_pkey)` 중복 키 에러가 발생하지 않도록 멱등성(Idempotency)이 완벽히 보장됩니다.

3.2 OIDC / OAuth2 SSO 설정 절차

1. SecretStore에 OIDC Client Secret을 안전하게 저장합니다:

```
postra secret set --type oidc_client_secret --label "Keycloak SSO Client Secret"
# 출력을 통해 시크릿 참조 키(예: sec_a1b2c3d4) 확인
```

2. 환경변수 설정 후 서버를 실행합니다:

```
export POSTRA_OIDC_ENABLED=true
export POSTRA_OIDC_ISSUER="https://auth.company.com/realms/postrа"
export POSTRA_OIDC_CLIENT_ID="postra-client"
export POSTRA_OIDC_CLIENT_SECRET_REF="sec_a1b2c3d4"
./postra serve
```

3.3 자동 로그인 (silent SSO, `auth.oidc.auto_login`)

Keycloak(또는 ReSSO)에 이미 로그인한 사용자가 Postra를 열면 로그인 화면을 거치지 않고 바로

본 화면으로 들어가게 하는 기능입니다. **기본값은 꺼짐**이며, 관리 화면(시스템 설정 → Keycloak

OIDC SSO)의 "이미 로그인한 사용자는 로그인 화면 없이 자동 로그인" 체크박스 또는

`POSTRA_OIDC_AUTO_LOGIN=true` 로 켭니다. 꺼져 있는 설치에서는 아무것도 달라지지 않습니다.

동작 방식:

- 로그인 화면이 열리면 브라우저가 `/ui/auth/oidc/start?prompt=none` 으로 **최상위 이동**합니다

(숨은 `iframe` 이 아니므로 서드파티 쿠키 차단·프레임 정책과 무관합니다). `prompt=none` 은

제공자 화면을 절대 그리지 않습니다 — Keycloak 세션이 있으면 인가 코드가 바로 돌아와 평소처럼

로그인되고, 없으면 `error=login_required` 로 돌아옵니다. 이것은 실패가 아니라 평범한 대답이며, 서버는 `/ui/login?sso=none` 으로 보내 일반 로그인 화면을 보여 줍니다.

- 서버는 `auto_login` 이 꺼져 있으면 `?prompt=none` 이 붙어 와도 조용히 평범한 로그인으로

바꿉니다. 주소를 손봐서 흐름을 바꿀 수는 없습니다.

- 깊은 링크(예: `/ui/messages/...`)로 들어온 사용자는 로그인 뒤 그 자리로 돌아갑니다.

`return_to` 는 `/` 로 시작하고 `//` 로 시작하지 않는 앱 내부 경로만 받습니다.

- 거절이 아닌 **진짜 실패**(잘못된 client secret, 허용되지 않은 scope·redirect_uri, 비활성 사용자,

자동 생성 꺼짐 등)는 콜백 주소에 머무르지 않고 `/ui/login?sso=error` 로 보내며, 사유는

서명된 일회용 쿠키(`postra_oidc_error`, 60초)로 전달돼 로그인 화면에 한 번만 표시됩니다.

콜백 주소(`code=...&state=...`)에 머무르면 새로고침마다 이미 쓴 코드를 다시 보내 장애 기록만

쌓이므로 그 자리를 떠나는 것입니다. 사유는 서버 로그에 남고, 토큰 교환·검증 실패는 장애 화면에도 기록됩니다.

무한 루프 방지(세 겹): (1) 한 탭 세션에 한 번만 시도 — `sessionStorage` 표시, 새 탭은 다시

시도하지만 거절 뒤 새로고침은 시도하지 않음. (2) 로그아웃 직후에는 시도하지 않음 —

로그아웃 시 억제 표시를 남기고 세션이 다시 생기면 지움. (3) 콜백이 거절을 받으면

`/ui/login?sso=none` 으로 보내 주소에도 표시를 남김 — 브라우저 저장소가 비워져도 재시도하지

않음. 사생활 보호 모드처럼 저장소를 읽지 못하면 "이미 시도했다" 로 간주해 막히는 쪽으로

실패합니다. `sso=` 표시(`none` · `error` · `signed_out`)가 붙은 로그인 화면과 오류 화면, API·MCP·

헬스 경로에서는 시도하지 않습니다.

확인 절차:

- Keycloak 에 로그인한 상태로 Postra 를 열면 로그인 화면 없이 본 화면이 뜹니다.
- 로그인하지 않은 상태로 열면 로그인 화면이 한 번에 뜨고, 새로고침을 반복해도 리다이렉트가

반복되지 않습니다.

- 로그아웃한 뒤 다시 열어도 자동으로 로그인되지 않습니다.

4. Envelope Encryption & SecretStore 구조

Postra는 사내 민감 데이터 보호를 위해 2중 봉투 암호화 메커니즘을 적용합니다.

```

+-----+
|  POSTRA_KEK (Master 32-Byte Key)  |
+-----+
|
|  Encrypts / Decrypts
|
v
+-----+
| Envelope Structure (crypto.Envelope) |
| - KeyVersion: 1                      |
| - EncryptedDEK: Base64(AES-GCM-KW(DEK)) |
| - Ciphertext:  Base64(AES-GCM-Payload(Data, AAD)) |
+-----+

```

4.1 SecretStore 암호화 레코드 스키마 (secrets.enc.json / db_secrets)

```

{
  "sec_8f9a2b1c": {
    "envelope": {
      "key_version": 1,
      "nonce": "...",
      "encrypted_dek": "...",
      "ciphertext": "..."
    },
    "owner": "admin",
    "type": "mail_password",
    "label": "업무 메일 수신 암호",
    "version": 1,
    "revoked": false
  }
}

```

4.2 KEK 로테이션 및 Self-Healing

- 비밀값 로테이션 (CLI):

```
postra secret rotate --ref sec_8f9a2b1c
```

- 자가 치유 (Self-Healing): KEK 변경 또는 파드 교체로 `secret_acquire` 에러 발생 시, Web UI 계정 편집 페이지에서 비밀번호를 다시 입력하고 저장하면 최신 KEK로 자동 재암호화 및 등록이 완료됩니다.

5. ObjectStore 백엔드 및 저장 구조 (Object Storage)

Postrа는 메일 원문(RFC822 MIME) 및 첨부파일을 두 가지 어댑터 방식으로 관리합니다.

5.1 LocalObjectStore (파일 시스템 기반)

- 경로: `$POSTRA_DATA_DIR/objects/{raw|att}/xx/yyyy...`
- 파일명: SHA-256 해시값 기반의 2자 서브디렉터리 분할 저장

5.2 DBObjectStore (데이터베이스 기반)

- 테이블: `object_blobs`
- 스키마 DDL (PostgreSQL 기준):

```
CREATE TABLE IF NOT EXISTS object_blobs (  
    bucket VARCHAR(64) NOT NULL,  
    object_key VARCHAR(255) NOT NULL,  
    content_type VARCHAR(128) NOT NULL,  
    size_bytes BIGINT NOT NULL,  
    data BYTEA NOT NULL,  
    created_at BIGINT NOT NULL,  
    PRIMARY KEY (bucket, object_key)  
);
```

6. 장애 모니터링 및 이벤트 파이프라인 (Incidents & Observability)

Postrа v0.10.0+는 장애 및 시스템 이벤트 추적 파이프라인을 지원합니다.

6.1 대시보드 및 REST API

- 대시보드: `http://:8480/ui/admin/incidents`
- REST API: `GET /api/incidents?severity=error&limit=50`
- JSON 응답 구조:

```
[
  {
    "id": "inc_99a8b7c6",
    "severity": "warning",
    "category": "sync_interrupted",
    "title": "POP3 Sync Interrupted",
    "detail": "Connection reset by peer during retrieve",
    "created_at": 1774345200
  }
]
```

6.2 Prometheus 메트릭 수집 (/metrics)

- `postra_sync_total{status="succeeded|failed"}` : 동기화 처리 건수
- `postra_messages_fetched_total` : 수집된 신규 이메일 수
- `postra_outbox_pending_messages` : 발송 대기 큐 크기
- `postra_attachment_blocked_total` : 악성 첨부파일 차단 횟수

6.3 방문 추적 스크립트와 콘텐츠 보안 정책(CSP)

관리자는 `/ui/admin/settings` 의 **방문 추적** 카드에서 화면에 추적 도구를 붙일 수 있습니다. 설정은 시스템 설정 저장소 (`tracking.*` 키)에 들어가며 REST `PATCH /api/admin/settings` 로도 바꿀 수 있습니다. **기본값은 꺼짐입니다** — 새로 설치한 곳에서는 어떤 화면에도 스크립트가 붙지 않고, 정책도 달라지지 않습니다.

설정 키	기본값	뜻
<code>tracking.enabled</code>	<code>false</code>	관리자가 켜야 스니펫이 붙습니다
<code>tracking.provider</code>	<code>none</code>	<code>momento</code> · <code>ga4</code> · <code>gtm</code> · <code>matomo</code> · <code>custom</code>
<code>tracking.momento_url</code> · <code>tracking.momento_site_id</code>	(없음)	Momento 수집기 주소와 사이트 id
<code>tracking.momento_proxy</code>	<code>true</code>	<code>/momento/*</code> 를 앱이 수집기로 넘기는 같은 오리진 프록시
<code>tracking.measurement_id</code>	(없음)	GA4 · GTM 의 id
<code>tracking.matomo_url</code> · <code>tracking.matomo_site_id</code>	(없음)	Matomo 주소와 사이트 id
<code>tracking.custom_snippet</code>	(없음)	붙여넣은 스니펫. 8KB 를 넘으면 저장되지 않습니다
<code>tracking.allowed_hosts</code>	(없음)	스니펫에서 자동으로 읽지 못한 출처를 더하는 자리 (선택 구분)
<code>tracking.include_admin</code>	<code>false</code>	<code>/ui/admin/*</code> 에서도 추적할지
<code>tracking.placement</code>	<code>head</code>	<code>head</code> 또는 <code>body</code> (문서 끝)

Momento 를 먼저 씁니다. Momento 는 사내 자체 호스팅 수집기라 방문 데이터가 밖으로 나가지 않는 유일한 선택지입니다. 기본값인 프록시 모드에서는 스니펫이 `/momento/tracker.js` 를 부르고 `data-endpoint="/momento"` 로 신고하므로, 브라우저는 Postra 오리진하고만 통신하고 정책에 외부 출처가 아예 등장하지 않습니다. 프록시를 끄면 `tracking.momento_url` 의 출처가 정책에 더해집니다. 프록시로 넘길 때 세션 쿠키와 `Authorization` 헤더는 제거됩니다.

←!— 프록시 모드에서 실제로 나가는 마크업 →

```
<script nonce="..." async src="/momento/tracker.js" data-site-id="<site id>"
  data-environment="prd" data-contract-version="1" data-endpoint="/momento"></script>
```

CSP 가 어려운 쪽입니다. Postra 의 화면은 `script-src 'self'` 로 잠겨 있어 스니펫을 그냥 붙이면 브라우저가 조용히 막고, 관리자는 화면이 비어 있는 이유를 알 수 없습니다. Postra 는 다음과 같이 처리합니다.

1. **요청마다 nonce** — 모든 UI 응답에 새 nonce 를 만들어 `script-src 'self' 'nonce-...'` 로 내보내고, 레이아웃의 자체 스크립트와 스니펫의 **모든**